

# VANTAGE / VeriCall

## Simple 3-Day Fix Planner

For 2 people: one backend/AI owner + one frontend/deploy owner

### The goal is NOT to make it bank-grade in 3 days.

- Make it safe enough to deploy as a credible prototype.
- Remove the embarrassing fake parts that reviewers will catch quickly.
- Be honest in the README about provider-ready integrations.
- Get one full demo flow working end-to-end.

| YOU / PERSON A - Backend + AI                                                                                                                                                                         | FRIEND / PERSON B - Frontend + Deploy                                                                                                                                                                  |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <ul style="list-style-type: none"><li>■ Security fixes</li><li>■ OTP + rate limit</li><li>■ Liveness + face match backend</li><li>■ Agent next-question logic</li><li>■ Mock bureau honesty</li></ul> | <ul style="list-style-type: none"><li>■ Remove fake UI data</li><li>■ Admin dashboard integration</li><li>■ Dynamic liveness UI</li><li>■ AWS/frontend deploy</li><li>■ README + demo polish</li></ul> |

### One rule for the 3 days

- Person A owns backend files. Person B owns frontend, infra, and docs.
- Do not both edit backend/main.py, backend/models.py, README.md, or API client files at the same time.
- Agree API names first, then work separately.

# 1. What is actually broken?

Keep this page open while working. These are the credibility killers.

| Area       | Problem in simple words                                               | Fix goal                                                     |
|------------|-----------------------------------------------------------------------|--------------------------------------------------------------|
| OTP        | OTP is printed to console and stored in memory.                       | Real provider/interface + expiry + attempts + rate limit.    |
| Security   | CORS is too open. Deepgram key goes to browser. Demo passwords exist. | Restrict CORS, hide keys, remove unsafe defaults.            |
| Liveness   | UI says show fingers, backend only checks emotion.                    | Backend must verify actual challenge frames.                 |
| Face match | Uses image/hash logic instead of facial biometrics.                   | Use DeepFace/real verification, fail safely.                 |
| Bureau     | Credit score is fake/mock but used for decisions.                     | Separate mock provider and block real approval in mock mode. |
| Agents     | There are agent modules, but questions are too scripted.              | Add state-based next question + tool results + escalation.   |
| Admin      | Dashboard has fake/hardcoded data.                                    | Real cases list + review actions + audit timeline.           |
| Deploy     | Infra is partial and secrets/storage are not production-clean.        | Enough AWS deploy + honest docs + env config.                |

## Do NOT claim this after 3 days

- Do not say: production-ready fintech platform.
- Do not say: real RBI-compliant lending engine.
- Do not say: real CIBIL/UIDAI/GST integration unless actually licensed and connected.

## Safe claim after fixes

- AI-powered loan onboarding prototype with agentic workflow, KYC verification pipeline, RAG-based policy citations, admin review, and AWS deployment readiness.

## 2. Master Priority Board

This is the only priority order you need. Do not jump to nice UI polish before these are done.

| DO FIRST - Must fix                                                                                                                                                                                                                                                                                                                                                                                                  | DO SECOND - Should fix                                                                                                                                                                                                                                                                                       | CUT IF SHORT                                                                                                                                                                                                                                                                 |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <ul style="list-style-type: none"><li>■ CORS restricted</li><li>■ Deepgram key not exposed</li><li>■ OTP not printed to console</li><li>■ OTP expiry + attempt limit</li><li>■ Rate limiting</li><li>■ Liveness not emotion-only</li><li>■ Face match not hash-based</li><li>■ Mock bureau clearly labelled</li><li>■ Admin uses real backend data</li><li>■ README honest about mock/provider-ready parts</li></ul> | <ul style="list-style-type: none"><li>■ Dynamic agent next question</li><li>■ Application status persistence</li><li>■ Review/approve/reject flow</li><li>■ Input validation</li><li>■ Better error states</li><li>■ Audit timeline</li><li>■ Health check endpoint</li><li>■ Production env files</li></ul> | <ul style="list-style-type: none"><li>■ CloudFront</li><li>■ Advanced analytics</li><li>■ CSV export</li><li>■ Perfect mobile polish</li><li>■ Full CIBIL integration</li><li>■ Full UIDAI/GST integration</li><li>■ Fancy animations</li><li>■ Complex dashboards</li></ul> |

### Tiny rule

- If a feature is fake and cannot be made real in 3 days, make it HONEST instead of pretending.
- Example: call it MockBureauProvider and block final approval, instead of pretending it is real credit scoring.

# Day 1: Stop the obvious red flags

| PERSON A - Backend / AI                                                                                                                                                                                                                                                                                                                                                                                     | PERSON B - Frontend / Deploy                                                                                                                                                                                                                                                                                                                                                                                                                    |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <ul style="list-style-type: none"> <li>■ Fix CORS to allow only frontend URL</li> <li>■ Remove raw Deepgram key endpoint or proxy it</li> <li>■ Remove demo password defaults</li> <li>■ Add required env validation on startup</li> <li>■ Add OTP provider interface</li> <li>■ Stop printing OTP in console</li> <li>■ Add OTP expiry + wrong-attempt limit</li> <li>■ Add basic rate limiting</li> </ul> | <ul style="list-style-type: none"> <li>■ Find all hardcoded admin/dashboard data</li> <li>■ Create frontend API service layer</li> <li>■ Make API base URL env-driven</li> <li>■ Add loading/error/empty states</li> <li>■ Replace fake dashboard cards with API placeholders</li> <li>■ Update liveness UI to wait for backend result</li> <li>■ Prepare case list + case detail layout</li> <li>■ Write down required API contract</li> </ul> |

| Test checkpoint                                                                                                                                                                                                                                                                            | Cannot skip                                                                                                                                            | Cut if behind                                                                                                                                          |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------|
| <ul style="list-style-type: none"> <li>■ Backend starts only with required env vars</li> <li>■ OTP send does not print secret OTP in production</li> <li>■ Frontend no longer depends on localhost URL</li> <li>■ Admin page can load real API response or graceful empty state</li> </ul> | <ul style="list-style-type: none"> <li>■ CORS fix</li> <li>■ Deepgram key fix</li> <li>■ OTP no-console fix</li> <li>■ Frontend env API URL</li> </ul> | <ul style="list-style-type: none"> <li>■ Fancy dashboard styling</li> <li>■ CloudFront</li> <li>■ CSV export</li> <li>■ Advanced animations</li> </ul> |

## Day 2: Make verification + agents believable

| PERSON A - Backend / AI                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      | PERSON B - Frontend / Deploy                                                                                                                                                                                                                                                                                                                                                                                 |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <ul style="list-style-type: none"> <li>■ Create backend liveness challenge endpoint</li> <li>■ Generate random challenge: 2 fingers / 3 fingers / thumbs up</li> <li>■ Verify challenge using frames, not emotion</li> <li>■ Replace hash face match with DeepFace verify</li> <li>■ Fail safely if no face is detected</li> <li>■ Add ConversationState object</li> <li>■ Add next-question logic based on missing fields</li> <li>■ Rename bureau to MockBureauProvider</li> <li>■ Block real APPROVED status if bureau is mock</li> </ul> | <ul style="list-style-type: none"> <li>■ Fetch liveness challenge from backend</li> <li>■ Display dynamic challenge text</li> <li>■ Capture multiple frames</li> <li>■ Send frames to backend for verification</li> <li>■ Show pass/fail/manual review state</li> <li>■ Connect admin case list to backend</li> <li>■ Connect case detail page</li> <li>■ Add approve/reject/needs-review buttons</li> </ul> |

| Test checkpoint                                                                                                                                                                                                                                                                                                                   | Cannot skip                                                                                                                                                                                   | Cut if behind                                                                                                                                                                                  |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <ul style="list-style-type: none"> <li>■ Liveness challenge comes from backend</li> <li>■ UI does not say verified until backend confirms</li> <li>■ Face match returns actual verification status</li> <li>■ Agent asks different next question based on missing data</li> <li>■ Admin can see at least one real case</li> </ul> | <ul style="list-style-type: none"> <li>■ Liveness backend+frontend alignment</li> <li>■ Face match replacement</li> <li>■ Mock bureau honesty</li> <li>■ Basic dynamic agent state</li> </ul> | <ul style="list-style-type: none"> <li>■ Advanced head-turn detection</li> <li>■ Perfect risk scoring</li> <li>■ Real CIBIL/UIDAI/GST integrations</li> <li>■ Complex admin filters</li> </ul> |

## Day 3: Deploy + make it post-worthy

| PERSON A - Backend / AI                                                                                                                                                                                                                                                                                                                                            | PERSON B - Frontend / Deploy                                                                                                                                                                                                                                                                                                       |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <ul style="list-style-type: none"> <li>■ Add Pydantic input validation</li> <li>■ Add health check endpoint</li> <li>■ Add audit event creation for each step</li> <li>■ Improve error messages</li> <li>■ Add timeouts for external API calls</li> <li>■ Run backend Docker build</li> <li>■ Help set ECS env variables</li> <li>■ Final API test pass</li> </ul> | <ul style="list-style-type: none"> <li>■ Final frontend build</li> <li>■ Deploy frontend to S3</li> <li>■ Deploy backend to ECS/Fargate</li> <li>■ Connect frontend to ALB/API URL</li> <li>■ Update README honestly</li> <li>■ Add screenshots</li> <li>■ Create demo script</li> <li>■ Record/test one full demo flow</li> </ul> |

| Test checkpoint                                                                                                                                                                                                                                                                          | Cannot skip                                                                                                                                                       | Cut if behind                                                                                                                                                 |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <ul style="list-style-type: none"> <li>■ Local full flow works</li> <li>■ Docker backend works</li> <li>■ Frontend build works</li> <li>■ AWS deployed URL opens</li> <li>■ README does not overclaim</li> <li>■ Demo flow can be shown without explaining fake console hacks</li> </ul> | <ul style="list-style-type: none"> <li>■ Health check</li> <li>■ Frontend-backend connection</li> <li>■ Honest README</li> <li>■ One full working demo</li> </ul> | <ul style="list-style-type: none"> <li>■ CloudFront</li> <li>■ Perfect infra diagram</li> <li>■ Beautiful screenshots</li> <li>■ Optional features</li> </ul> |

## 6. Merge-Conflict Prevention Map

This page matters. Most 2-person projects fail because both people edit the same files.

| PERSON A owns                                                                                                                                                                                                                                                                     | PERSON B owns                                                                                                                                                                                                                                                                   | Both must avoid touching together                                                                                                                                                                                            |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <ul style="list-style-type: none"><li>■ backend/main.py</li><li>■ backend/config.py</li><li>■ backend/models.py</li><li>■ backend/vision.py</li><li>■ backend/agents/*</li><li>■ backend/services/*</li><li>■ backend/session_log.py</li><li>■ backend/requirements.txt</li></ul> | <ul style="list-style-type: none"><li>■ frontend/src/app/*</li><li>■ frontend/src/components/*</li><li>■ frontend/src/lib/*</li><li>■ frontend/src/types/*</li><li>■ infra/aws/*</li><li>■ README.md on Day 3</li><li>■ DEPLOYMENT.md</li><li>■ frontend/.env.example</li></ul> | <ul style="list-style-type: none"><li>■ backend/main.py</li><li>■ backend/models.py</li><li>■ frontend/src/lib/api.ts</li><li>■ README.md</li><li>■ .env.example</li><li>■ requirements.txt</li><li>■ package.json</li></ul> |

### Branch plan

- Person A: backend/security-auth-hardening -> backend/verification-agentic-core -> backend/production-finalization
- Person B: frontend/remove-hardcoded-ui -> frontend/liveness-admin-integration -> deploy/docs-public-ready
- Merge into dev at the end of each day. Final dev -> main on Day 3.

## 7. Minimal API Contract

Agree this first. Person B can build frontend while Person A implements backend.

| Endpoint                                 | Purpose              | Frontend needs                             |
|------------------------------------------|----------------------|--------------------------------------------|
| POST /api/otp/send                       | Send OTP             | mobile_number -> ok/message                |
| POST /api/otp/verify                     | Verify OTP           | mobile_number + otp -> session/token       |
| GET /api/liveness/challenge              | Get random challenge | challenge_id + instruction                 |
| POST /api/liveness/verify                | Verify frames        | challenge_id + frames -> passed/confidence |
| POST /api/agent/orchestrate              | Dynamic agent step   | state + message -> next_question/status    |
| GET /api/admin/applications              | Admin case list      | id/name/status/risk/created_at             |
| GET /api/admin/applications/{id}         | Case details         | profile, checks, timeline, documents       |
| POST /api/admin/applications/{id}/review | Review action        | approve/reject/needs_review + note         |
| GET /health                              | AWS health check     | ok/version/dependencies                    |

### Important

- Person B should not wait for perfect backend. Use these endpoint shapes and mock only at API-client level temporarily.
- Person A should keep response names stable. Changing API response keys late will waste time.



# 8. Final Posting Readiness Gate

Only post when most of this page is checked. If any red item is unchecked, do not overclaim.

| Red gate - must be checked                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           | Green gate - good enough to post                                                                                                                                                                                                                                                                                                                                                                                                                                              |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <ul style="list-style-type: none"><li>■ OTP is not printed in production logs</li><li>■ OTP has expiry + attempt limit</li><li>■ CORS is not wildcard in production</li><li>■ Deepgram/raw API keys are not exposed</li><li>■ Liveness backend verifies the same challenge shown in UI</li><li>■ Face match uses actual face verification or fails safely</li><li>■ Mock bureau cannot create real APPROVED status</li><li>■ Admin dashboard reads real backend data</li><li>■ Frontend uses production API URL</li><li>■ README does not claim fake integrations are real</li></ul> | <ul style="list-style-type: none"><li>■ One full demo flow works on deployed URL</li><li>■ Screenshots are clean</li><li>■ Admin can review a case</li><li>■ Agent asks at least some dynamic questions</li><li>■ Errors are user-friendly</li><li>■ Health check works</li><li>■ Docker build passes</li><li>■ Project has a clear architecture explanation</li><li>■ Mock/provider-ready pieces are clearly listed</li><li>■ LinkedIn caption uses honest wording</li></ul> |

## Final wording for public post

- Use: AI-powered loan onboarding prototype with agentic verification flow, RAG-based policy citations, admin review, and AWS deployment.
- Avoid: production-ready fintech platform, RBI-compliant loan engine, real KYC/bureau verification unless those are actually connected.